EKSAMEN – TK2100 INFORMASJONSSIKKERHET Kandidat 48

Contents

EKSAMEN – TK2100 INFORMASJONSSIKKERHET Kandidat 48 0
Oppgave 1. Generelt 1
C.I.A 1
A.A.A 2
Oppgave 2. Overvåkning 3
Oppgave 3. Skadevare 4
Oppgave 4. Kryptering 5
Oppgave 5. Personlig sikkerhet 5
Oppgave 6. Web sikkerhet 7
Oppgave 7. Nettverk 7
Oppgave 8. Hjemmekontor 8
Oppgave 9. Praktisk anti-virus 8
Praktisk demonstrasjon 8
Oppgave 10. Praktisk server-side angrep 10
Kilder 12

Oppgave 1. Generelt

Informasjonssikkerhet kan man kort forklare at handler om sikring av informasjon. Dette er dog en veldig kort og mangelfull forklaring som ikke nevner flere av de viktigste punktene ved sikring av informasjon. Noen spørsmål som kan dukke opp om informasjonen: Er den tilgjengelig? Hvordan er den sikret? Hvem kan få tilgang til informasjonen? Hvordan får de tilgang til informasjonen? Hva er informasjon?

C.I.A

Informasjonssikkerhet har blitt definert med forskjellige modeller, og i denne oppgaven fokuserer jeg på C.I.A:
For ordens skyld har jeg oversatt de til Norsk også

- **C**onfidentiality // Konfidensialitet
- **I**ntegrity // Integritet
- **A**vailability // Tilgjengelighet
  (Goodrich & Tamassia, 2011, s. 3)

C.I.A modellen handler om at vi skal sikre data ved å følge tre hovedpunkter, der konfidensialitet er først ut. Konfidensialitet handler om å unngå uautorisert tilgang til informasjonen, men samtidig tillatte autorisert tilgang. Om tilgangen er manuelt utført av en bruker eller en automatisert prosess har ingenting å si, den som trenger og har autorisert tilgang må kunne hente ut informasjonen. Følgende verktøy kan brukes for dette:

- Kryptering
- Adgangskontroll systemer
- Autentifikasjon
- Autorisasjon
- Fysisk sikkerhet

Disse verktøyene har forskjellig funksjon og varierer i sikkerhetsgrad, men de vil alltid være å anbefale.
Sikker og fremtidssikker **kryptering** sikrer at data er uleselig for uautoriserte brukere og at kun autoriserte brukere har tilgang til krypteringsnøkkelen / dekrypteringsnøkkelen.
Adgangskontroll systemer kontrollerer at kun brukere med tilgang til området eller filsystemet kommer seg i nærheten av informasjonen.
Autentifikasjon passer på at brukeren er den som den faktisk utgir seg for å være og ikke noen andre. Dette er ofte utført ved å bruke en kombinasjon av noe du er, noe du vet og noe du har. For eksempel biometri, passord, og fysisk sikkerhetsnøkkel.
Autorisasjon bekrefter at brukeren som er autentifisert tidligere faktisk har tilgang til filen, og ikke kun andre filer.
Fysisk sikkerhet passer på at den lagrede informasjonen er bak fysiske sikkerhetssystemer. Hvis en uautorisert bruker får tilgang til systemet og kan hente ut maskinvare er dette kritisk. Dette gir direkte tilgang til datasystemer og flere av verktøyene vil til slutt bli brutt i fremtiden. Om de blir brutt av kvantemaskiner eller andre svakheter (for eksempel Zero-Day) er umulig å si. Det er derfor viktig at sikkerhet er relevant til hva informasjon som lagres. Hvis du lagrer statshemmeligheter er det

kanskje et stort problem hvis en statsaktør får tilgang, men selger du printere er det kanskje ikke et like stort problem at en hacker fra Bulgaria som selger eposter får tilgang til kryptert data.
(Goodrich & Tamassia, 2011, s. 3–6; Østby, 2025e, s. 33–40)

Integritet er neste og er vel så viktig, her skal informasjon ikke kunne bli endret av uautorisert personell. Altså, kun brukere som har tilgang til informasjonen OG har endringsrettigheter skal kunne endre på dataen. For å forsikre seg om dette er det viktig at verktøy blir brukt:

- Backup
- Sjekksummer
- Data-opprettelse (Alternative sjekksummer)

Backup er veldig viktig. Dette sikrer at selv om informasjonen blir borte et sted kan den «enkelt» hentes tilbake gjennom alternative lagringsplasser. Her anbefales backup—prinsippet 3.2.1 som betyr at du burde ha 3 kopier av informasjonen, 2 forskjellige lagringsmedier, 1 kopi på et annet sted. (*What Is a 3-2-1 Backup Strategy?*, u.å.)
Forskjellige metoder for å regne ut **sjekksummer** kan brukes, men i profesjonelle settinger har jeg erfart at mange firmaer bruker MD5 mot sluttkunden. Dette er en type fingeravtrykk som kan verifisere at dataen ikke er endret, så lenge sjekksummen ikke er endret. Her er det viktig å ha en kopi av den originale sjekksummen.
Data-opprettelse er en type sjekksum, men er ofte brukt i et system for å enkelt kunne tilbakeføre den endrede filen til original filen.
(Goodrich & Tamassia, 2011, s. 6–7; Østby, 2025e, s. 41)

Sist, men ikke minst er det tilgjengelighet sin tur. Her er det viktig at den autoriserte og godkjente brukeren som skal ha tilgang, får tilgang innen «relativt» kort tid. Her må «relativt» bli bestemt ut ifra hvor kritisk og godt sikret informasjonen er.
Noen verktøy her er:

- Fysisk beskyttelse
- Redundans

Fysisk beskyttelse innebærer at informasjonen er gjort tilgjengelig med relevant fysisk sikkerhet og løsninger som garanterer tilgang. Dette vil ofte være generatorer, brann- og/eller bombe-sikkert rom.
Redundans sikrer at utfall av data ikke vil skje eller ha stor skade når det skjer. Dette kan være automatisk bytting av nettverksruting ved utfall eller oppsett av RAID for automatisk feilretting ved utfall av lagringsmedium.
(Goodrich & Tamassia, 2011, s. 8)

A.A.A

Man kan også bruke A.A.A, men det fokuserer jeg ikke på i denne oppgaven.
A.A.A står for:

- Assurance // Sikring
- Authenticity // Autentisitet
- Anonymity // Anonymitet
  (Goodrich & Tamassia, 2011, s. 9)

Oppgave 2. Overvåkning

I oppgaven vil jeg bytte på å bruke Etterretningstjenesten og e-tjenesten, de betyr det samme og er underlagt Forsvaret/Forsvarsjefen. (*Etterretnings-tjenesten*, 2024)

All nettverkstrafikk i Norge eller som krysser landegrensen er overvåket av Etterretningstjenesten (§7-2 *Lov om Etterretningstjenesten (etterretningstjenesteloven) - Kapittel 7*, 2021). Oppgaven nevner Etterretningstjenesteloven kapittel 7, og for ordens skyld har jeg arkivert loven pr 28.04.2025 her - https://web.archive.org/web/20250428114401/https://lovdata.no/dokument/NL/lov/2020-06-19-77/KAPITTEL#KAPITTEL

Etterretningstjenesteloven §7 tilsier at Etterretningstjenesten kan innhente informasjon om all datatrafikk som krysser landegrensen mellom utland og Norge (§7 *Lov om Etterretningstjenesten (etterretningstjenesteloven) - Kapittel 7*, 2021). §7-2 er enda mer spesifikk om hva informasjon de kan hente ut og hvordan de kan bruke det. I denne loven står det også «a. gi informasjon om signalmiljø, dataformater, tekniske innretninger og fremgangsmåter», «b. tillate at tjenesten installerer utstyr og etablerer tilstedeværelse for å drifte utstyr på steder som kontrolleres av tilbyder» og «e. sørge for tilgang til kommunikasjon uten hinder av linkkryptering eller tilsvarende kryptering som tilbyder kontrollerer». (§7-2 *Lov om Etterretningstjenesten (etterretningstjenesteloven) - Kapittel 7*, 2021)
Basert på min forståelse av §7-2 og de nevnte over så kan e-tjenesten innhente all trafikk vi sender, installere hva de vil på e-kom tilbydere sitt utstyr og ikke bli hindret av noen form for kryptering som tilbyder kontrollerer. Da de aller fleste internettjenester vi bruker er i utlandet eller samhandler med diverse tjeneste i utlandet vil alt vi gjør kunne spores ned til spesifikke personer. I praksis betyr dette at alt vi gjør er overvåket.
For meg så er dette ikke etisk riktig, da vi har rett på respekt for privatliv gjennom Den europeiske menneskerettskonvensjonen artikkel 8 og Norges grunnlov §102 (*Hva er personvern?*, 2023). Når de først samler inn all denne informasjonen så blir konfidensialitet og integritet veldig viktig. Hvordan lagres informasjonen, hvem har direkte tilgang til den og er e-tjenesten ærlig med EØS utvalget som skal overvåke de? (§7-11 *Lov om Etterretningstjenesten (etterretningstjenesteloven) - Kapittel 7*, 2021)
I 2013 lakk Edward Snowden graderte dokumenter fra NSA, der det ble avslørt at Norge var/er med i USA sin Nine Eyes etterretnings «klubb».
Etterretningstjenesten i Danmark (Forsvarets Etterretning) ble i 2020 tatt i å ha et ulovlig samarbeid med NSA. Her ble det tilrettelagt for overvåkning av dansk internettrafikk av NSA. For å gjøre vondt verre ble det også tilbakeholdt informasjon fra Tilsynet med Efterretningstjenesterne, noe som forhindret tilsynet fra å avdekke NSA sin overvåkning. (Østby, 2025b, s. 36–40)
Siden vi mest sannsynlig blir overvåket av NSA enten i hjemlandet eller når vi interagerer med systemer i USA er «Chilling effect» en interessant teori. Det innebærer at mennesker avstår fra handlinger de vanligvis ville gjort fordi de er under overvåkning. Handlinger vi ser på som «vanlige» for eksempel medlemskap i et politisk parti vil muligens bli unngått. Vil vi stoppe å tenke like fritt? Unngår vi samhandling med spesifikke religioner da de kan ha radikale medlemmer? Blir vi sakte, men sikkert «kuet»? Dette er seriøse etiske problemer overvåkning bringer med seg og er noe jeg mener vi ikke tar seriøst nok som samfunn. (Murray et al., 2024)

Oppgave 3. Skadevare

Virus og orm kan fort plukkes opp på internett når man besøker forskjellige internettsider, spesielt ved feilklikk på ondsinnede annonser som ruter trafikken innom falske nettsider også kalt malvertising. (*Malvertising*, u.å.)
Men hva er egentlig forskjellen?

Virus sprer seg ved at brukeren må interagere med en fil som er infisert, dette kan være en Word Macro som du får tilsendt fra en kollega. Brukeren må åpne dokumentet og godta aktivering av makroer for at viruset skal kunne infisere systemet og spre seg til andre filer eller applikasjoner. Når den sprer seg, gjemmer den seg ofte i andre filer og endrer deler av filen for å kunne overleve. Viruset kan endre .dll filer eller office dokumenter sine maler. Samtidig som dette skjer vil viruset endre dll export-tabellen med systemkall til seg selv eller andre programmer den har infisert og lagt seg imellom original kode. Hvis denne brukeren sender et infisert dokument videre vil viruset kunne spre seg hvis anti-virus ikke plukker det opp. Hvis anti-virus plukker det opp vil den nye brukeren være trygg, men hvis den ikke gjør det vil den nye brukeren bli infisert og fortsette reisen til viruset. (Latto, 2020; Østby, 2025c, s. 19–25)

Historisk sett ble det første viruset funnet i 1986 og het «Brain» eller «Pakistani Brain». Det var egentlig et forsøk fra et Pakistansk firma på å håndtere et piratkopiert dataprogram de hadde skrevet. Hvis en infisert IBM PC kjørte piratkopien av programmet deres så ville brukeren bli informert om dette og firmaet sin kontaktinformasjon ville dukke opp på skjermen. Viruset spredde seg via disketter og infiserte oppstarts sektoren til disketten. (Harán, 2018; Østby, 2025c, s. 16)

En orm er litt likt virus, men sprer seg selv og infiserer ikke andre programmer. Du kan enda få en orm tilsendt i et Word-dokument, men det hjelper som regel ikke at du ikke åpner det. En orm er derimot muligens litt farligere enn et virus, da den sprer seg selv. Hvis din maskin blir infisert, er det stor sjans for at det skjer automatisk at andre enheter på nettverket ditt også blir infisert. Den store forskjellen er at ormer ofte har med seg en skadelig nyttelast. Denne nyttelasten kan være alt fra ufarlig spøk til livsfarlig ransomware. (Latto, 2020; Østby, 2025c, s. 30–34)

Historisk sett ble den første ormen funnet i 1988 av Robert Tappan Morris. I hovedsak brukte den svakheter som ble funnet i Unix, svake passord, verktøy for uthenting av brukerinformasjon og remote shell execution. Robert sin orm infiserte systemer i rekordfart. Originalt ville han kun se hvor mange systemer som hadde internettilknytning, men det endte med et denial of service angrep og 3 års fengsel. (Østby, 2025c, s. 31)

Oppgave 4. Kryptering

Asymmetrisk kryptering kan brukes for å signere data ved at to personer sine ulike private nøkler brukes for å regne ut en krypteringsnøkkel/dekrypteringsnøkkel ved at de har tilgang på en lik offentlig nøkkel. Så, 1 person har tilgang på 1 privat nøkkel og en offentlig nøkkel. 1 annen person har tilgang på 1 egen privat nøkkel og den offentlige nøkkelen som den andre personen også har. Den offentlige nøkkelen er den eneste de deler kunnskap om. Ved bruk av en privat nøkkel og den offentlige nøkkelen kan begge parter dekryptere dataen de har sendt til hverandre uten at noen andre vil kunne dekryptere den, selv med en offentlig kjent nøkkel en angriper vil ha tilgang til.
Dette er veldig lett forklart, og er i teorien i seg selv sikkert, men ikke anbefalt alene. Det er derimot anbefalt å bruke så lenge du bruker en public key algoritme som bygger på denne metoden. En metode som bruker asymmetrisk kryptering, er RSA, ofte kalt RSA-XXXX bits. Her bruker vi RSA og bits på modulus. I 2010 var 2048 bits ansett som anbefalt, men i 2024 anbefales det 8196. (Goodrich & Tamassia, 2011, s. 412; Østby, 2025a, s. 47–50, 55–57)

Ifølge Bengt Østby sin forelesning om Kryptering er dette mattestykket til krypteringsalgoritmen RSA:
Velg to store primtall som er P og Q. Regn ut N = PQ og Z = (P-1)(Q-1).
Velg krypteringsnøkkel E, krav om at E<N.
Dekrypteringsnøkkel må velges, sett den til D. Regn ut ED modulus Z = 1
Offentlig nøkkel er (N,E), privat nøkkel er (N,D)
M er meldingen som er kryptert.
For å kryptere må man gjøre følgende «C = M ^{e}modulus N» og for å dekryptere må man gjøre følgende «M = C ^{d}modulus N
(Østby, 2025a, s. 56–57)

Personen som skal dekryptere har som oftest sniffet seg fram til de to offentlige nøklene, og mangler nå de private nøklene. Personen må faktorisere N slik at den blir P*Q. Videre må personen så kunne gjette D som er dekrypteringsnøkkel. For en vanlig datamaskin tar dette ekstremt lang tid, men en kvante-maskin vil bruke kortere tid. For en vanlig maskin tar dette lenger tid enn det er verdt for personen. (Østby, 2025a, s. 59)

RSA og Asymmetrisk kryptering bidrar til kryptering av data enkelt og uten bytting av nøkler. Ved å signere og kryptere for eksempel epost med denne metoden vil dette være et verktøy som kan gjøre at tilgjengelighet og konfidensialitet i CIA modellen blir ivaretatt. (Østby, 2025a, s. 64)

Oppgave 5. Personlig sikkerhet

Personlig sikkerhet og sporbarhet er noe jeg personlig setter veldig høyt. Det er verdt å nevne at grepene er gjort over tid, og at flere av de er ikke noe som allmennheten kommer til å gjøre.

1. **Epostleverandør og eget domene**
   Jeg bruker en epostleverandør fra et land der personvern står sterkt. Her er også epostene mine kryptert når de er lagret, og jeg betaler for tjenesten selv.

Jeg bruker også flere private domener så jeg står fritt ledig til å bytte epostleverandør ved utfall av tjeneste eller endring i lovgiving for landet de opererer i.
Dette gjør at jeg blir mindre sporet av epostleverandøren, og er ikke deres produkt som for eksempel gmail.
For meg er dette viktig da epost ofte kan ha en del halv-personlig informasjon og jeg får mindre annonser på internett for alt mulig.

2. **Epost aliaser**
   Dette er ikke et steg mange tar, men jeg så meg ekstremt lei all reklame man får på epost fra steder man blir tvunget til å ha bruker eller oppgi informasjon.
   Ved bruk av aliaser kan jeg enkelt skru av et spesifikt alias hvis det blir solgt, brukt for reklame eller delt etter et angrep.
   For meg er dette viktig da jeg heller får viktig eposter levert med varsler og alt annet havner i satte mapper uten varsling. Dette leder til mer fri fra mobilen og mindre avledninger fra virkeligheten.
3. **Passordmanager**
   Dette er et grep som ofte er diskutert, men et valg jeg har tatt.
   Jeg bruker passordmanager for å ha lange, sikre og gode passord + brukernavn. Da slipper jeg å huske masse lange passord, får enkelt tilgang.
   Dette løser problemet med gjenbrukte og svake passord som mange aldri husker.
   Dette er viktig for meg da flere tjenester har en del informasjon som ikke er offentlig tilgjengelig og tjenesten varsler meg om forskjellige datainnbrudd jeg kan ha vært en del av.
4. **VPN**
   For meg er det viktig med vpn som ikke har logger. Det gjemmer internettrafikken min fra offentlige nett og ikke minst vanskeliggjør for eksempel sporing fra e-tjenesten. Jeg betaler også for denne tjeneste så jeg ikke er produktet.
5. **Nettverksbasert annonse og sporingsbeskyttelse // Pi-Hole**
   Jeg blokkerer en del annonser og sporingsforespørsler på nettverksnivå og i forbindelse med DNS.
   Her bruker jeg flere lister over kjente annonse- og sporings tilknyttede url'er.
   Dissen blir luket ut i DNS forespørsler på nettverksnivå, så ikke for eksempel oppvaskmaskinen ikke skal kunne sende informasjon.
   Dette er viktig for meg som et ledd i kombinasjon med alle leddene over, rett og slett for å hindre annonser og sporing av meg som person på internett.

Oppgave 6. Web sikkerhet

Cross Site Request Forgery (CSRF) er det motsatte av XSS. Altså, det er nettsidens fortrolighet til brukeren som blir misbrukt i et CSRF angrep og ikke en brukers fortrolighet til nettsiden. (Goodrich & Tamassia, 2011, s. 364)
Eksempel: Du er innlogget på en krypto markedsplass og chatter med andre. Noen sender en lenke, og du trykker på denne. Lenken ser uskyldig ut og tar deg til wikipedia, men det var ikke originalt wikipedia som sto i url'en. Før du ble sendt til wikipedia var uvisst innom en nettside som inneholdt javascript kode som kunne overføre krypto til en spesifikk lommebok.
<script> document.location="http: //www.cryptomarketplace.io/transferBTC .php?amount=25&fromID=6543&toID=7894";</script> (Goodrich & Tamassia, 2011, s. 364)

Dette angrepet skiller seg fra andre liknende web angrep ved at det er nettsiden som blir lurt til å tro at brukeren har utført en genuin handling. Dette angrepet kan brukes for å endre brukerinnlogging til nettsider eller hente ut data som brukeren har innlogget tilgang til. Alt brukeren har tilgang til på nettsiden har angriperen også. (*What Is CSRF (Cross Site Request Forgery)?*, u.å.)Dette gjelder dog ikke hvis det er brukt anti-CSRF teknikker som for eksempel Anti-CSRF tokens eller SameSite flagger i cookies.
Anti-CSRF tokens er ment for å beskytte serveren fra et CSRF angrep, og er en tilfeldig tekststreng som kun nettleseren og serveren vet om. Uten denne tekst strengen så vil ikke serveren godta noe som helst fra brukeren og den blir kun sendt i et «hidden»-felt. (*Cross-Site Request Forgery (CSRF)*, u.å.)
SameSite flagger i cookies fungerer ved at forespørsler som kommer fra et annet domene enn domenet som satt på forhånd i cookien ikke blir godtatt. Dette forhindrer ikke at angriperen sender forespørsler fra hoved-domenet, og vil da kunne misbruke CSRF igjen. (*What Is CSRF (Cross Site Request Forgery)?*, u.å.)

Oppgave 7. Nettverk

I linklaget har vi flere sikkerhetsutfordringer, og de er ikke nødvendigvis de enkleste å løse. Selv om MAC-adresser er forhåndsdefinert er det mulig å endre de, og da lure både switcher og rutere. Ved endring av MAC kan du i teorien «bli» en annen maskin og få tilsendt informasjon eller få tilgang til intra-net som du ikke skal. Hvis tjenester også kun tillater innlogging fra spesifikke MAC-adresser vil du også få tilgang til disse, med mindre de er ordentlig sikret. (Østby, 2025d, s. 8–11)
Et annet problem her, er bruken av ARP og tilkoblingen mellom nettverk og linklaget. Alle forespørsler som blir sendt blir cachet og oppdatert. Dette åpner opp for forfalskning av forespørsler og kan lede til diverse angrep, for eksempel man-in-the-middle angrep. Her får angriperen fri tilgang og kan innhente informasjon eller sniffe påloginger til diverse nettsider du besøker. Det er verdt å nevne at dette er ulovlig og åpner opp for fengselsstraff. (Østby, 2025d, s. 12–16)

Beskyttelse mot flere av disse angrepene er ved å bruke diverse verktøy, men det ikke standardisert. Vi kan for eksempel bruke kryptering for å hindre at data havner i feil hender, eller bruke sjekksummer for å verifisere nedlastninger eller filer. Da vet vi i at

kun den tiltenkte mottageren har tilgang på krypteringsnøkkelen og/eller at filene vi sender er ekte og umodifiserte. (Østby, 2025d, s. 5)

Oppgave 8. Hjemmekontor

Under og etter COVID har det blitt mer og mer vanlig med hjemmekontor i alle mulige jobber. Alt fra kontorarbeid til it-administrasjon. Ifølge INTERPOL i 2020 skiftet cyberkriminelle siktet sitt fra individuelle personer eller små bedrifter til statlige aktører, kritisk infrastruktur og store bedrifter. Fra januar til april 2020 ble det rapportert inn til INTERPOL 907 000 spam meldinger, 737 tilfeller relatert til skadevare og 48 000 domener som hadde skadevare i seg. Alle disse forsøkene ble rapportert til INTERPOL fra EN av partnerne deres. (*INTERPOL Report Shows Alarming Rate of Cyberattacks during COVID-19*, 2020)

Jeg tror at økning og fortsettelsen av hjemmekontor vil bidra til at skadelig angrep fortsetter i høy takt mot arbeidstakere i statlige organisasjoner, kritisk infrastruktur og store bedrifter som nevnt over. Dette er fordi de har informasjonen andre statlige aktører vil ha, og der kan de gjøre mest skade. Enten om det er en statelig aktør eller en ransomware gruppe. Her kan de hente ut informasjon eller låse ned systemer og selge tilgang eller informasjon videre. Flaten som må sikres av i alle ledd har vokst i rekordfart. Svakheter i tidligere sikringstiltak vil komme frem og det kan fort hende at det ikke er innført noe ordentlig sikring før bruken av hjemmekontor eksploderte. Sikring av forskjellige plattformer tar tid, noe organisasjoner muligens ikke har mye av før neste cyberangrep.
Da mennesket er det svakeste ledd når vi bruker teknologi, så vil det måtte være et mye høyere krav til sluttbruker om sikker bruk av systemer. Interne og eksterne kurs, opplæring i trygg bruk av internett og proaktiv generell kursing vil nok være en god løsning. (Shakeel, 2023)

Oppgave 9. Praktisk anti-virus

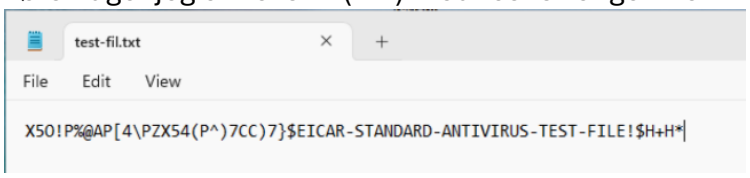
I denne oppgaven startet jeg opp en virtuell maskin og brukte anti-virus programmet Bitdefender sin gratis versjon. Denne tekststrengen er laget for å teste reaksjonsevnen til anti-virus programmer ved å bruke en tekststreng som er definert på forhånd og delt med alle anti-virus bedrifter.
Dette er følgende streng:
X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
(«Download Anti Malware Testfile», u.å.)

Denne test strengen er valgt for å ikke måtte dele en potensielt farlig fil når anti-virus programmer blir testet. («Download Anti Malware Testfile», u.å.)

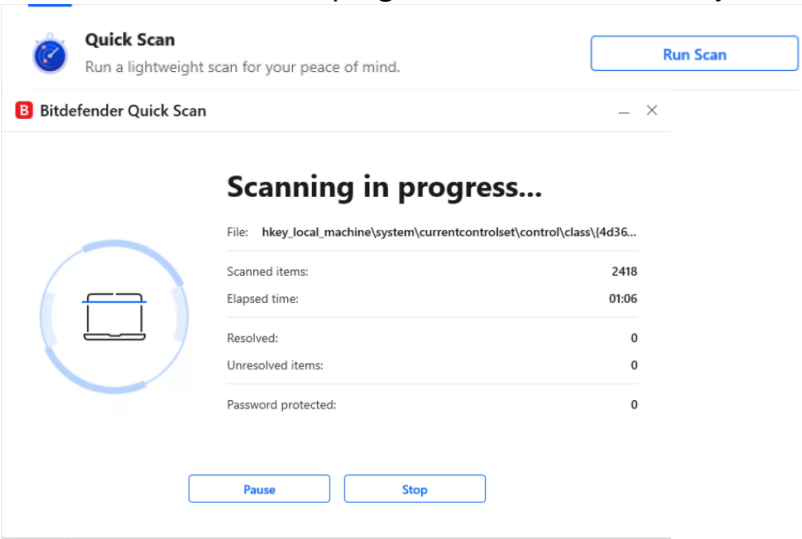
Praktisk demonstrasjon

OBS: For den praktiske demonstrasjonen er sanntidsbeskyttelse kalt Bitdefender Shield i Bitdefender skrudd av. Dette er for å forhindre at test filen skal bli detektert umiddelbart. Alle skanninger er gjort ved å manuelt starte de i anti-virus programmet.

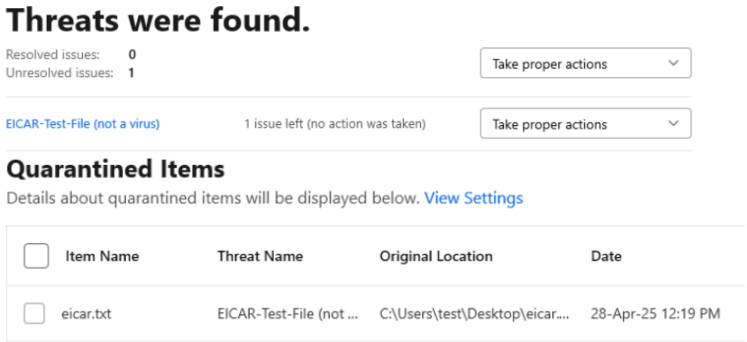
1. Først lager jeg en tekstfil (.txt) med test strengen nevnt over



2. Så skanner jeg hele systemet med anti-virus programmet
   Dette er for at anti-virus programmet skal lete etter kjent skadevare

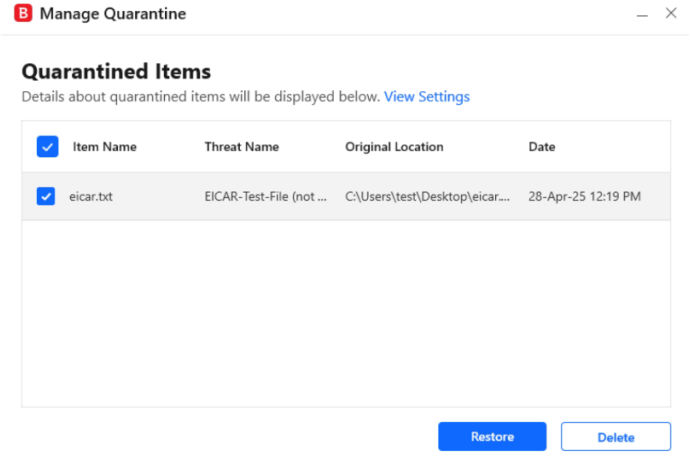


3. Anti-virus programmet fant filen og ba meg velge hva jeg vil gjøre med den. Jeg velger å sette den i karantene for å beskytte systemet mitt. Anti-virus gjenkjente til og med filen som en «EICAR-Test-File».

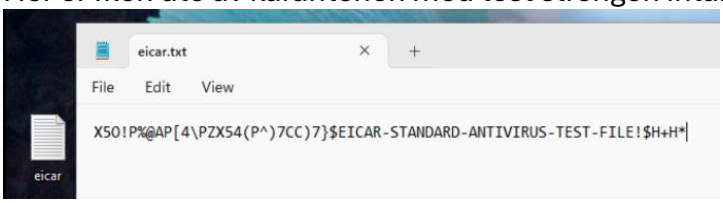


4. For å slippe filen ut av karantene gjør jeg følgende:
   Protection → Settings →Manage quaratine → Merker filen → Restore

OBS: Husk at sanntidsbeskyttelse er skrudd av.

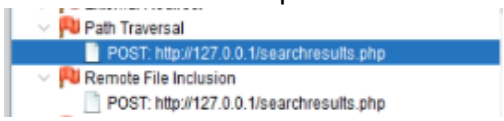


5. Her er filen ute av karantenen med test strengen intakt



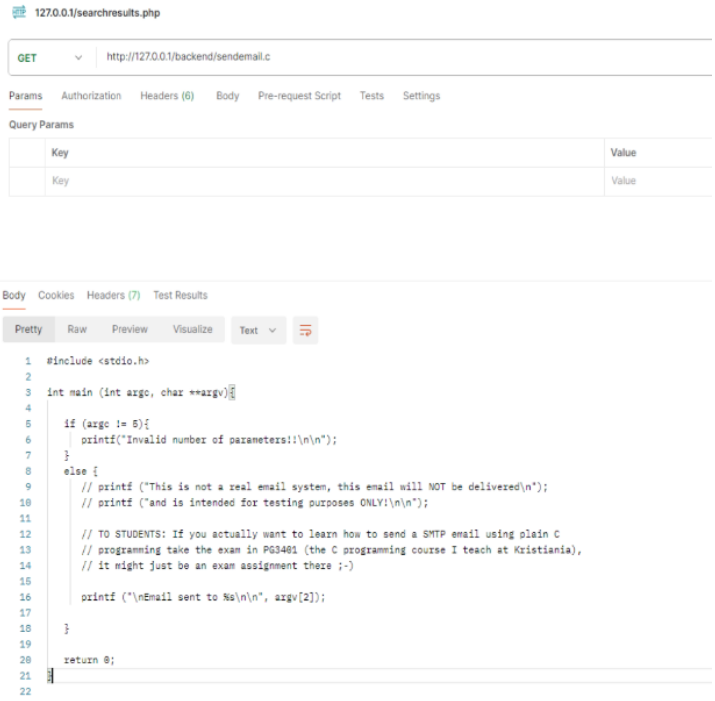
Oppgave 10. Praktisk server-side angrep

For å utføre et local file inclusion angrep begynte jeg først å finne dokumentasjon på internett. Etter en skanning med ZAP ble det funnet Path traversal og Remote File Inclusion svakheter på /searchresults.php.

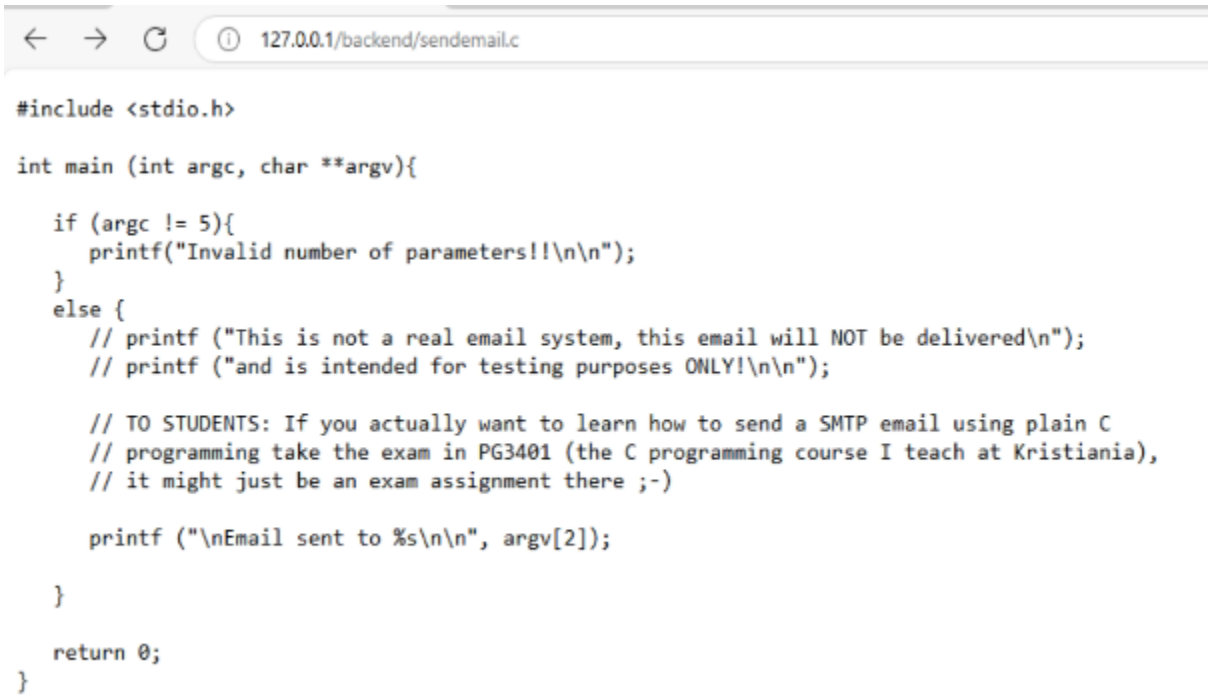


Jeg gikk så videre med testing av diverse funksjoner i php som kunne utnyttes. «/searchresults.php?file=%255backend%255sendemail.c» og lignende kommandoer ble brukt. Her fikk jeg masse feilmeldinger med «Undefined array key» og feil knyttet til backurl. Etter dette startet jeg POSTMAN for å gjennomgå post forespørsler og etter en god dose testing, fikk jeg opp innholdet i filen med følgende kommando: «127.0.0.1/backend/sendemail.c». (*File Inclusion/Path traversal*, u.å.)

POSTMAN:



Nettleser:



Kilder

Cross-site request forgery (CSRF). (u.å.). Mdn Web Docs. Hentet 28. april 2025, fra https://developer.mozilla.org/en-US/docs/Web/Security/Attacks/CSRF

Download Anti Malware Testfile. (u.å.). *EICAR*. Hentet 28. april 2025, fra https://www.eicar.org/download-anti-malware-testfile/

Etterretnings-tjenesten. (2024, september 8). Forsvaret. https://www.forsvaret.no/om-forsvaret/organisasjon/etterretningstjenesten

File Inclusion/Path traversal. (u.å.). Hentet 28. april 2025, fra https://book.hacktricks.wiki/en/pentesting-web/file-inclusion/index.html#file-inclusion

Goodrich, M. T., & Tamassia, R. (2011). *Introduction to Computer Security* (1. utg.). Pearson.

Harán, J. M. (2018, mai 11). *Malware of the 1980s: Looking back at the Brain Virus and the Morris Worm*. Welivesecurity. https://www.welivesecurity.com/2018/11/05/malware-1980s-brain-virus-morris-worm/

Hva er personvern? (2023, juli 26). Datatilsynet. https://www.datatilsynet.no/rettigheter-og-plikter/hva-er-personvern/

INTERPOL report shows alarming rate of cyberattacks during COVID-19. (2020, april 8). https://www.interpol.int/en/News-and-Events/News/2020/INTERPOL-report-shows-alarming-rate-of-cyberattacks-during-COVID-19

Latto, N. (2020, august 13). *Worm vs. Virus: What's the Difference and Does It Matter?* Worm vs. Virus: What's the Difference and Does It Matter? https://www.avast.com/c-worm-vs-virus

Lov om Etterretningstjenesten (etterretningstjenesteloven)—Kapittel 7. (2021, januar 1). [Lovdata]. Lov om Etterretningstjenesten (etterretningstjenesteloven). https://lovdata.no/dokument/NL/lov/2020-06-19-77/KAPITTEL_7#KAPITTEL_7

Malvertising. (u.å.). Malwarebytes. Hentet 28. april 2025, fra https://www.malwarebytes.com/malvertising

Murray, D., Fussey, P., Hove, K., Wakabi, W., Kimumwe, P., Saki, O., & Stevens, A. (2024). The Chilling Effects of Surveillance and Human Rights: Insights from Qualitative Research in Uganda and Zimbabwe. *Journal of Human Rights Practice*, *16*(1), 397–412.

Shakeel, I. (2023, juni 9). *When humans are the weak link in critical infrastructure cybersecurity | Security Magazine*. https://www.securitymagazine.com/articles/99867-when-humans-are-the-weak-link-in-critical-infrastructure-cybersecurity

What is a 3-2-1 Backup Strategy? (u.å.). Seagate.Com. Hentet 28. april 2025, fra https://www.seagate.com/blog/what-is-a-3-2-1-backup-strategy/

What is CSRF (Cross Site Request Forgery)? (u.å.). Fortinet. Hentet 28. april 2025, fra https://www.fortinet.com/resources/cyberglossary/csrf

Østby, B. (2025a, januar 13). *TK2101 Informasjonssikkerhet—Kryptering* [Forelesning]. https://kristiania.instructure.com/courses/13674/files/1547088?module_item_id=531965

Østby, B. (2025b, januar 20). *TK2101 Informasjonssikkerhet—Personvern* [Forelesning]. https://kristiania.instructure.com/courses/13674/files/1550980?module_item_id=533922

Østby, B. (2025c, januar 27). *TK2101 Informasjonssikkerhet—Malware* [Forelesning]. https://kristiania.instructure.com/courses/13674/files/1555062?module_item_id=535790

Østby, B. (2025d, mars 17). *TK2101 Informasjonssikkerhet—Nettverkssikkerhet* [Forelesning]. https://kristiania.instructure.com/courses/13674/files/1586186?module_item_id=543869

Østby, B. (2025e, juni 1). *TK2101 Informasjonssikkerhet—Introduksjon* [Forelesning]. https://kristiania.instructure.com/courses/13674/files/1547086?module_item_id=531962